

Seguridad y Resiliencia | Parte 1: minimizacion de datos y credenciales

Que datos se recolectan, cuales se decidieron NO recolectar, y donde vive cada secreto

Principio aplicado: si no lo uso, no lo pido

El formulario de captacion recoge cuatro campos. Cada uno tiene una funcion concreta en el proceso; si no la tuviera, no estaria.

- nombre -> personalizar el trato en la respuesta
- email -> unico canal por el que se contesta
- empresa -> senal de clasificacion (equipo = mayor prioridad)
- mensaje -> materia prima que el modelo interpreta

Se decidio NO pedir: telefono, direccion, documento de identidad, facturacion, ni cargo dentro de la empresa. Ninguno interviene en la decision de clasificar ni en la de responder, y cada dato de mas es superficie de riesgo sin contrapartida.

Donde vive cada credencial

Ninguna clave esta escrita dentro del escenario ni viaja en el blueprint que se publica en el repositorio.

- Airtable -> Personal Access Token con alcance limitado a una sola base y a tres permisos: leer, escribir y ver esquema.
- Slack -> OAuth de usuario, revocable desde el workspace.
- Gemini -> keychain cifrado de Make; el escenario la referencia por ID, nunca por valor.

En el blueprint exportado, cada conexion aparece como un numero de referencia. Quien clone el repositorio obtiene la logica completa del sistema y ningun acceso a los datos.

Incidente registrado durante la construccion | rotacion de credencial

Durante el desarrollo, la clave de API de Gemini quedo expuesta al compartirse fuera de su almacen seguro. Se aplico el procedimiento estandar: la clave se considero comprometida de inmediato, se revoco desde la consola del proveedor y se genero una nueva, que se cargo directamente en el keychain de Make sin pasar por ningun canal intermedio.

Se documenta el episodio porque ilustra la unica politica sensata frente a un secreto expuesto: una credencial que salio de su lugar seguro no se evalua, se rota. El costo de rotarla es de un minuto; el de asumir que nadie la vio es indeterminado. Este mismo criterio es el que exige la consigna al pedir que las claves esten ocultas en el video de demostracion.

Encuadre normativo

MARCO	QUE EXIGE	COMO LO CUMPLE ESTE SISTEMA
GDPR minimizacion	Recolectar unicamente los datos necesarios para la finalidad declarada.	Cuatro campos, todos con funcion verificable en el flujo. El mensaje original se conserva sin editar porque es la evidencia que sustenta la clasificacion.
GDPR consentimiento	El contacto debe haber iniciado el vinculo o consentido explicitamente.	El sistema solo responde a quien escribio primero. No hay envio en frio ni importacion de listas: es reactivo por diseno.
IA Act nivel de riesgo	Clasificar el sistema segun su impacto sobre las personas.	Riesgo limitado. No decide sobre credito, empleo, salud ni educacion: ordena consultas comerciales y propone un borrador que un humano aprueba.
IA Act transparencia	Poder explicar por que el sistema decidio lo que decidio.	El campo Justificacion IA guarda, en cada registro, el razonamiento del modelo en dos oraciones. La caja negra queda abierta y auditable lead por lead.

Seguridad y Resiliencia | Parte 2: rutas de error y comportamiento ante fallos

Tres Error Handlers activos, con la directiva elegida en cada punto y su fundamento

Un sistema resiliente no es el que no falla, sino el que falla de forma predecible y deja rastro. La regla que ordena estas rutas: se corta el flujo cuando continuar produciria un dato incorrecto, y se continua cuando el fallo solo afecta a un aviso interno que no cambia el resultado para el lead.

PUNTO DE FALLO	QUE PUEDE SALIR MAL	DIRECTIVA	QUE HACE EL SISTEMA	POR QUE ESA DIRECTIVA Y NO OTRA
Registrar Lead (Airtable)	La API de Airtable no responde, el token vencio o un campo rechaza el valor recibido.	Break	Escribe un evento Error Airtable en el Log con el ID de ejecucion y detiene la corrida. La ejecucion queda en la cola de incompletas de Make.	Sin el registro creado no existe el ID que todos los modulos siguientes necesitan para actualizar. Continuar generaria una respuesta que no se puede asociar a ningun lead.
Motor de IA (Gemini)	La API devuelve 401 por credencial invalida, agota la cuota, o responde con un formato que no se puede parsear.	Break	Registra Error API IA en el Log, marca el lead como Error y detiene. El lead queda visible para reproceso manual.	Es el fallo mas probable y el que efectivamente ocurrio en las pruebas. Sin clasificacion no hay nada que aprobar; enviar algo igual seria peor que no enviar nada.
Notificar a Slack	El workspace no responde o la conexion perdio autorizacion.	Resume	Registra el evento y permite que el flujo siga hasta marcar el lead como Esperando Aprobacion.	Unico caso donde continuar es correcto: el aviso es un atajo, no el mecanismo. El lead queda igualmente en la vista de pendientes de Airtable y el validador lo ve ahi.
Enviar respuesta (Gmail)	Gmail rechaza el envio, la direccion es invalida o la conexion expiro.	Break	Registra Error Gmail, revierte el lead a estado Error y detiene antes de marcarlo como Enviado.	Marcar Enviado un mensaje que nunca salio corromperia el KPI de conversion y dejaria al lead sin respuesta sin que nadie lo note.

Evidencia de funcionamiento | los Error Handlers capturados en produccion

Durante las pruebas del 18/08/2026, el modulo de IA fallo de forma sostenida por un problema de credencial del proveedor. El comportamiento observado fue exactamente el disenado:

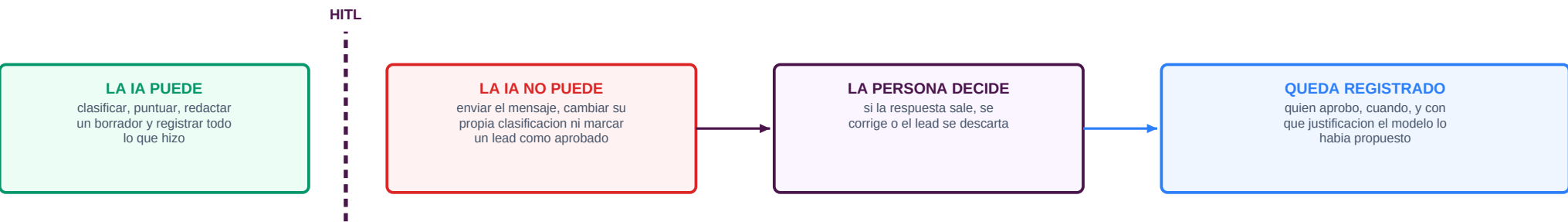
- El lead entrante se registro completo en la tabla Leads, con nombre, email, empresa, mensaje y canal de origen. Ningun dato se perdio.
- El Error Handler capturo el fallo y escribio en el Log de Ejecuciones el ID de ejecucion, el modulo de origen, el tipo Error API IA y el detalle.
- La directiva Break detuvo la corrida y la deposito en la cola de ejecuciones incompletas, desde donde puede reintentarse sin volver a cargar el lead.
- Ninguna respuesta se envio al lead. El sistema fallo sin contactar a nadie por error.

El estado WARNING que muestra Make es el resultado correcto: indica que una ruta de error se activo y contuvo el fallo, no que el escenario este mal construido.

Seguridad y Resiliencia | Parte 3: puntos de validacion humana

Donde se detiene el sistema, que decide la persona y que no puede hacer la IA por si sola

La linea que la automatizacion no cruza sola



El sistema se detiene por completo antes de la unica accion irreversible que puede ejecutar: escribirle a una persona real. Esa frontera esta implementada de forma estructural, no como una advertencia ni una configuracion: el Escenario 1 no tiene ningun modulo capaz de enviar correo, y el Escenario 2 solo actua sobre registros que ya figuran en estado Aprobado por Humano. Aunque el modelo se equivoque por completo en su clasificacion, no existe camino tecnico por el que ese error alcance al lead sin que alguien lo haya leído y aprobado.

ASPECTO	COMO ESTA RESUELTO	QUE PASA SI FALLA	POR QUE ASI
Punto de detencion	Al terminar la clasificacion, el lead queda en Esperando Aprobacion y el Escenario 1 finaliza.	Si nadie aprueba, no pasa nada. El lead permanece en la cola indefinidamente.	La inaccion es el estado seguro. Un sistema que actua solo cuando lo dejan esperando es un sistema que no controla nadie.
Como se notifica	Mensaje a Slack con el borrador completo, la categoria, el puntaje, la justificacion y un enlace directo al registro.	Si Slack falla, el lead sigue visible en la vista de pendientes de Airtable.	La notificacion acelera la revision pero no es el mecanismo de control. El control es el estado en la base.
Como se aprueba	La persona cambia el campo Estado a Aprobado por Humano. Ese cambio es el unico disparador del envio.	Un cambio de estado erroneo se revierte antes de que el Escenario 2 lo detecte.	Se eligio el cambio de estado en vez de un boton en Slack: deja rastro en la base, es reversible y no depende de un tercer sistema.
Que queda auditado	Estado final, campo Aprobado por, fecha de envio, justificacion del modelo y el mensaje de Slack.	El Log de Ejecuciones conserva el evento aunque el lead se edite despues.	Permite reconstruir, meses despues, que propuso la IA y que decidio la persona en cada caso.

Check de seguridad previo a la entrega

- Filtro contra bucles infinitos: el modulo 2 descarta remitentes noreply y no-reply y exige que existan email y mensaje. Ademàs, el trigger es un webhook: solo se ejecuta cuando llega un dato nuevo, por lo que el sistema no puede dispararse a si mismo con su propia salida.
- Comparacion de tipos correcta: los filtros comparan texto contra texto (Estado, Categoria IA, dominios del remitente). El unico campo numerico, Score IA, no se usa como condicion de ruteo, de modo que no hay comparaciones entre numero y cadena en ningun punto del flujo.
- Prompt dinamico: el prompt no contiene ningun dato fijo del lead ni del catalogo. Recibe cuatro variables del webhook y el bloque de servicios recuperado de Airtable en tiempo de ejecucion.